

Multi-Framework Compliance Report

Document:	Cloud_Security_and_Data_Protection_Policy.docx
Analyzed By:	khizarahmedd3@gmail.com
Analysis Date:	2025-11-09
Overall Score:	45/100
Status:	Non-Compliant
Frameworks Analyzed:	4

Framework Compliance Scores

Framework	Score	Status
Azure Best Practices	50/100	Non-Compliant
GDPR	45/100	Non-Compliant
ISO 27001	40/100	Non-Compliant
ISO 27018	48/100	Non-Compliant

Executive Summary

Multi-framework compliance analysis complete. Overall score: 45/100 (Non-Compliant). Analyzed against 4 frameworks: azure, gdpr, iso27001, iso27018.

Detailed Framework Analysis

Azure Best Practices

Score:	50/100
Status:	Partial

Recommendation:

Implement Azure role-based access control (RBAC) for all Azure resources, moving beyond administrator-only MFA. Enforce MFA for all users to align with Azure's identity management best practices. Implement geo-redundant backups using Azure's GRS or RA-GRS options.

Gaps Identified:

- MFA is only enabled for administrators, not standard users, which is a gap in Azure's recommended identity management practices.
- Public access is allowed for selected blob storage containers, violating Azure's storage security best practices.
- Geo-redundant backups are not yet implemented, failing to leverage Azure's built-in data redundancy features.
- NSGs allow inbound traffic on port 3389 (RDP), which is a security risk and deviates from Azure's network security recommendations.
- Application Insights is not implemented, limiting comprehensive monitoring capabilities within Azure.
- The document does not mention the use of Azure Key Vault for managing encryption keys.
- The document does not mention the use of Azure role-based access control (RBAC) to provide user-specific permissions.

Compliant Areas:

- Access to Azure resources is managed through Azure Active Directory (AAD).
- Critical databases are encrypted using Azure Disk Encryption.
- Transport Layer Security (TLS) 1.2 is enforced for data in transit.
- Virtual Networks (VNETs) are deployed to segment internal resources.
- Azure Monitor is configured for key services.
- Weekly data backups are performed.

Key Requirements:

- Use Azure role-based access control (Azure RBAC) to provide user-specific permissions.
- Secure Storage Accounts using Azure role-based access control (Azure RBAC).
- Use Data Plane Security to secure access to data using Shared Access Signatures (SAS) and Stored Access Policies.
- Use Transport-Level Encryption – Using HTTPS and the encryption used by SMB (Server message block protocols) 3.0 for Azure File Shares.
- Utilize Geo Redundant Storage (GRS) for data redundancy.

Priority Actions:

1. Implement MFA for all users in Azure Active Directory to enhance identity security.
2. Remediate public access to blob storage containers and implement appropriate access controls using SAS tokens or RBAC.
3. Configure geo-redundant backups for critical data to ensure business continuity in case of regional outages.
4. Harden Network Security Groups (NSGs) to restrict inbound traffic and remove unnecessary open ports like 3389 (RDP).
5. Implement Azure Application Insights for comprehensive application monitoring and performance analysis.

GDPR (General Data Protection Regulation)

Score:	45/100
Status:	Partial

Recommendation:

Implement a Data Protection Impact Assessment (DPIA) process for all data processing activities, especially those involving personal data in blob storage with public access. Also, formalize and regularly test incident response procedures, and implement anonymization or pseudonymization techniques to minimize data retention risks.

Gaps Identified:

- No Data Protection Impact Assessment (DPIA) is mentioned, which is required for high-risk processing activities as per Article 35 of GDPR.
- Public access to blob storage containers is a potential GDPR violation if personal data is stored there without appropriate safeguards.
- Incident response procedures are not tested regularly, which is a gap in meeting the security requirements of Article 32 of GDPR.
- Anonymization or pseudonymization techniques are not applied, increasing the risk associated with data retention as per Article 5 of GDPR.
- Data subject rights requests are handled manually via email, which may not be efficient or secure enough to comply with Articles 15-22 of GDPR.
- Service Level Agreements (SLAs) with vendors do not explicitly reference GDPR or ISO standards, which is important for demonstrating compliance with Article 28 of GDPR (Processor obligations).

Compliant Areas:

- Consent for data processing is obtained during account registration, which aligns with Article 6 of GDPR (Lawful basis for processing).
- Critical databases are encrypted using Azure Disk Encryption, which contributes to data security as required by Article 32 of GDPR.
- Transport Layer Security (TLS) 1.2 is enforced for data in transit, protecting data during transmission as per Article 32 of GDPR.
- Access to Azure resources is managed through Azure Active Directory (AAD), which helps control access to personal data.
- Password policies are in place, requiring a minimum level of complexity, which contributes to data security.

Key Requirements:

- Lawful basis for processing personal data (Article 6): The document mentions consent, but other lawful bases may be relevant depending on the processing activity.
- Data security (Article 32): Implementing appropriate technical and organizational measures to ensure a level of security appropriate to the risk.
- Data subject rights (Articles 12-23): Providing mechanisms for data subjects to exercise their rights, such as access, rectification, erasure, and data portability.
- Data Protection Impact Assessment (DPIA) (Article 35): Conducting a DPIA for processing activities that are likely to result in a high risk to the rights and freedoms of natural persons.
- Breach notification (Articles 33-34): Establishing procedures for notifying data breaches to the supervisory authority and data subjects, where required.

Priority Actions:

1. Conduct a Data Protection Impact Assessment (DPIA) for all processing activities involving personal data, especially those related to blob storage with public access.
2. Implement anonymization or pseudonymization techniques to reduce the risks associated with data retention and comply with Article 5 of GDPR.
3. Automate the handling of data subject rights requests to ensure timely and secure responses, and comply with Articles 15-22 of GDPR.

4. Update Service Level Agreements (SLAs) with cloud service providers and vendors to explicitly reference GDPR and relevant ISO standards, ensuring compliance with Article 28 of GDPR.
5. Enable Multi-Factor Authentication (MFA) for all users, not just administrators, to enhance data security and comply with Article 32 of GDPR.

ISO 27001:2022

Score:	40/100
Status:	Partial

Recommendation:

Develop and implement a comprehensive Information Security Management System (ISMS) that aligns with ISO 27001:2022, including documented policies and procedures for all Annex A controls. Prioritize implementing MFA for all users, not just administrators, and address the public access to blob storage.

Gaps Identified:

- Lack of a fully implemented and documented Information Security Management System (ISMS) as required by ISO 27001:2022.
- Multi-Factor Authentication (MFA) is only enabled for administrators, not standard users, failing to meet strong access control requirements (A.9).
- Blob storage currently allows public access for selected containers, violating data confidentiality principles (A.5, A.9).
- Incident response procedures exist but are not tested regularly, which is a gap in A.16.
- The document does not explicitly address physical security controls such as physical security perimeters, entry controls, equipment siting, and protection (A.11).
- The document does not mention confidentiality or non-disclosure agreements with personnel and relevant interested parties (6.6).
- The document does not mention security measures implemented when personnel are working remotely (6.7).
- The document does not mention a mechanism for personnel to report observed or suspected information security events (6.8).
- The document does not mention secure disposal or re-use of equipment (7.14).
- The document does not mention protection of information stored on, processed by or accessible via user end point devices (8.1).

Compliant Areas:

- Access to Azure resources is managed through Azure Active Directory (AAD) (A.9).
- Critical databases are encrypted using Azure Disk Encryption (A.10).
- Transport Layer Security (TLS) 1.2 is enforced for data in transit (A.10).
- Virtual Networks (VNETs) are deployed to segment internal resources (A.12).
- Network Security Groups (NSGs) restrict inbound traffic (A.12).
- Azure Monitor is configured for key services (A.12, A.16).
- Cloud service providers and vendors are assessed annually for security compliance (A.18).

Key Requirements:

- Establish, implement, maintain, and continually improve an information security management system (ISMS).
- Implement information security policies and procedures that address all applicable Annex A controls.
- Conduct regular internal audits and management reviews of the ISMS.
- Implement access control measures to restrict access to information and assets based on the principle of least privilege.
- Implement incident management procedures to detect, report, and respond to security incidents effectively.
- Ensure compliance with legal, statutory, regulatory, and contractual requirements related to information security.

Priority Actions:

1. Develop and implement a comprehensive ISMS based on ISO 27001:2022, including defining the scope, objectives, and policies.
2. Implement Multi-Factor Authentication (MFA) for all users accessing Azure resources to strengthen access control (A.9).
3. Review and remediate the public access configuration of blob storage containers to ensure data confidentiality (A.5, A.9).
4. Develop and regularly test incident response procedures to ensure effective handling of security incidents (A.16).
5. Implement physical security controls to protect areas containing information and associated assets (A.11).

ISO 27018:2019

Score:	48/100
Status:	Partial

Recommendation:

Implement a comprehensive consent management system that aligns with ISO 27018:2019 requirements, including explicit consent for specific data processing activities and mechanisms for withdrawing consent. Formalize procedures for handling data subject rights requests beyond email, ensuring timely and auditable responses. Implement anonymization or pseudonymization techniques where possible to minimize PII exposure.

Gaps Identified:

- Lack of explicit mention of controls to ensure data can only be accessed at the point of destination and not en route during transfer, as per ISO 27018:2019 requirements for information transfer (13.2.2).
- The document states that data subject rights requests are handled manually via email, which does not align with the requirement for robust and auditable processes for managing data subject rights under ISO 27018:2019.
- The document mentions consent is obtained during account registration, but lacks details on how consent is managed, tracked, and withdrawn, which is a critical aspect of ISO 27018:2019 compliance.
- The document does not explicitly address the use of unencrypted portable storage media and devices, and the associated documentation requirements as outlined in ISO 27018:2019 (A.11.5).
- The document lacks details on how the organization ensures transparency to cloud service customers regarding information security implementation and operation, including independent audit evidence, as required by ISO 27018:2019 (18.2.2).

Compliant Areas:

- Encryption of critical databases using Azure Disk Encryption aligns with PII protection requirements in the cloud.
- Enforcement of TLS 1.2 for data in transit supports the encryption of PII transmitted over public data-transmission networks (A.11.6).
- The document mentions obtaining consent for data processing during account registration, indicating an attempt to address consent management.
- Annual assessment of cloud service providers and vendors for security compliance demonstrates an effort to manage third-party risks.

Key Requirements:

- Obtaining and managing consent for processing PII in the cloud.
- Providing transparency to cloud service customers regarding information security implementation.
- Implementing controls to protect PII during transfer, ensuring it can only be accessed at the destination.
- Establishing robust processes for handling data subject rights requests.

- Implementing appropriate technical and organizational measures to protect PII against unauthorized access, disclosure, or loss.

Priority Actions:

1. Develop and implement a comprehensive consent management system that allows for explicit consent, tracking, and withdrawal of consent for PII processing.
2. Establish formal procedures for handling data subject rights requests, including mechanisms for verification, response, and audit logging.
3. Implement anonymization or pseudonymization techniques where feasible to reduce the risk associated with PII.
4. Review and update SLAs with cloud service providers to explicitly reference GDPR and ISO standards, ensuring clear responsibilities for PII protection.
5. Implement multi-factor authentication (MFA) for all users, not just administrators, to enhance access control and PII protection.